SentinelIQ 09 — ML & RAG Design

Oct 13, 2026 · @maxi

SentinelIQ scores events with a supervised model, retrieves ATT&CK knowledge for the risky ones, and asks an LLM to explain them using only what was retrieved.

Pipeline overview

Steps 2 to 7 run in the worker, so the ingestion API never waits for the model or the LLM.

1. **Normalize:** the event enters the unified schema defined in Document 04.
2. **Featurize:** the worker builds model features from the event and, for authentication logs, from recent history.
3. **Score:** the classifier returns a risk between 0 and 1, stored with the model version.
4. **Gate:** events at or above the threshold continue; the rest are stored without an explanation.
5. **Retrieve:** a text description of the event is used to search the ATT&CK knowledge chunks.
6. **Explain:** the LLM receives the event as data and the retrieved passages as context, and returns structured JSON.
7. **Validate:** the output must match the schema and cite only retrieved technique IDs; otherwise the explanation is marked failed and the event still reaches the queue.

Features

Source	Features	Notes
Network flows	The numeric flow features supplied by the dataset, such as duration, packet and byte counts, rates and flag counts	Identifier columns (addresses, timestamps, flow IDs) are dropped so the model learns behaviour, not hosts

Source	Features	Notes
Authentication logs	Failed logins per account in a recent window, distinct accounts tried per source address, time since last success, hour of day, first login from a new country	Computed by the worker from recent events; window lengths are documented in the code

Any scaling or encoding is fitted on the training split only and saved with the model, so scoring in production repeats exactly what training did.

Model choice and training

These choices are proposals, to be confirmed by the experiments in Phase 4.

Model	Role	Why
Logistic regression	Baseline	A simple reference, so every improvement is measured against something
Gradient-boosted trees	Primary classifier	Strong on tabular data, fast to score, and its feature importances help explain results
Isolation Forest	Unsupervised comparator	Trained on benign traffic only, to show how an anomaly detector behaves on attack types it has not seen

- **Imbalance:** class weights during training, and per-class results in the report.
- **Threshold:** chosen on the validation set to stay under the false-positive target in Document 01, then reported once on the test set. It is stored with the model version and stays configurable.
- **Reproducibility:** fixed random seeds; every training run records the data version, parameters and metrics in `model_versions`.

Evaluation plan

Pass bars are the proposed targets from Document 01 and will be revisited after the Phase 4 baseline.

Metric	Data	Pass bar
Attack recall	Held-out test split of the network flows	90% or higher
False-positive rate	Same test split	5% or lower
Per-class precision and recall	Same test split	Reported for every class; no single bar
Authentication-log detection	Synthetic test set with known patterns	Reported separately; never merged with the flow results
Explanation citation accuracy	Hand-labeled event set	80% or higher
Injection resistance	Fixed adversarial log lines	Reported as a count and a share

Knowledge base and retrieval

- **Source:** the public machine-readable (STIX/JSON) release of the MITRE ATT&CK Enterprise matrix. The release version is stored in `knowledge_chunks.attack_release`. Usage terms are checked, and MITRE is credited in the README.
- **Scope:** the full Enterprise matrix is indexed, so retrieval has to choose among many techniques; evaluation focuses on the subset below.
- **Chunking:** one chunk per technique or sub-technique, holding its ID, name, tactic and description; very long descriptions are split.
- **Embeddings:** produced through the same provider interface, stored in pgvector, with the embedding model name recorded. Changing the model means re-embedding everything.
- **Search query:** built from the event's structured fields (event type, counts, ports), never from free text an attacker controls.
- **Results:** start with the top 5 chunks and tune on the labeled set.

Candidate mapping from the attack types in the data to ATT&CK techniques. Each ID will be verified against the current ATT&CK release before use.

Attack type	Candidate technique	ID
Brute force, repeated failed logins	Brute Force	T1110
Password spraying	Brute Force: Password Spraying	T1110.003
Port scan	Network Service Discovery	T1046
DoS and DDoS	Network Denial of Service	T1498
Web attacks	Exploit Public-Facing Application	T1190
Login from an unusual place or time	Valid Accounts	T1078
Botnet traffic	To be assigned after reviewing the dataset's class details	None yet

Explanation generation

- **Prompt:** a fixed system prompt, stored under a version label that is saved with every explanation.
- **Separation:** the event and the retrieved passages sit in clearly delimited sections, and the prompt states that the event section is untrusted data.
- **Output format:** JSON with a short summary (about 80 words at most), technique IDs, a confidence level of low, medium or high, and up to three suggested checks for the analyst.
- **Validation:** the output must match the schema, and every technique ID must be among those retrieved. On failure the worker retries once, then marks the explanation failed.
- **Settings:** a low temperature, so the same event gives a stable explanation.
- **Failure behaviour:** the event still appears in the queue, labelled as having no explanation yet or a failed one.
- **Cost control:** explanations are generated only above the threshold, saved so they are never generated twice, and capped per day.

Explanation evaluation

This section fixes the size of the evaluation sets that Document 04 left open.

- **Labeled set (proposed size):** 60 events, 10 for each of six patterns (brute force, password spraying, port scan, DoS, web attack, unusual login), each paired with the correct ATT&CK technique, plus 10 benign events that score above the threshold, where the right answer is low confidence.
- **Citation accuracy:** the share of explanations whose main cited technique equals the ground truth or its parent technique. The target is 80% or higher.
- **Retrieval hit rate:** the share of events whose expected technique appears among the retrieved chunks, tracked separately so a poor explanation can be traced to retrieval or to generation.
- **Grounding rate:** the share of cited IDs that were actually retrieved. Validation should make this 100%, so any drop signals a bug.
- **Faithfulness check:** a person reads a sample of 20 explanations and confirms that every claim is supported by the event data.
- **Injection set (proposed size 20):** hostile log lines in four groups: attempts to override the instructions, to extract the prompt, to force a benign verdict, and to insert a fake technique ID. A line passes if the validated output ignores it. The pass rate is reported in the README.